

REGULATORY SCOPING REPORT

Finexa (example)

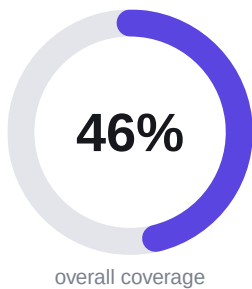
Digital infrastructure · Finexa SAS · SIREN 000 000 000 · Prepared by Firm consultant · For the attention of Thomas Lefèvre, deputy chief executive · Prepared on 25 September 2026

ENGAGEMENT	CAD-2026-014
OBJECTIVE	Establish which texts apply ahead of the 2027 ACPR audit and decide on this year's compliance budget.
PERIOD	7 September 2026 -> 16 October 2026
CONSULTANT	Firm consultant
SPONSOR	Thomas Lefèvre, deputy chief executive
GROUP	Independent
SCOPE	Payment institution authorised by the ACPR, 50 employees, operating in France, Belgium and Spain. Provides a cloud payment platform to merchants and publishes a payment SDK embedded in their applications.
CONTACTS	Karim Benali (CISO) · Claire Morel (DPO) · Inès Garnier (Compliance)

Summary

5 texts apply (GDPR, NIS2 (ReCyF), DORA, CRA, AI Act), i.e. 40 unified requirements. Reported coverage: 46%; 9 requirements with no measure at all, 17 partly covered.

OBLIGATIONS 61 232 elementary requirements	UNIFIED REQUIREMENTS 40 36 assessed	COVERAGE 46% partial counts for half	MAXIMUM PENALTY €20M GDPR cap
--	---	--	---



COVERAGE BY TEXT

GDPR		50%
NIS2 (ReCyF)		44%
DORA		42%
CRA		47%
AI Act		45%

BREAKDOWN BY TEXT

GDPR		36 req.
NIS2 (ReCyF)		31 req.
DORA		33 req.
CRA		15 req.
AI Act		22 req.

■ In place
■ Partial
■ Missing
■ Not assessed

01 Scoping against each text

Each verdict comes with the conditions of application examined. Caveats flag what remains to be confirmed outside the platform; amounts are the legal caps, applied to the declared turnover.

GDPR Regulation (EU) 2016/679		Applicable · Controller required to designate a DPO
LEGAL BASIS	CONDITION EXAMINED	STATUS
Article 2	Processing of personal data The entity reports processing personal data: the regulation applies materially.	Met
Article 3(1)	Establishment in the Union The entity is established in the Union: the territorial criterion is met, wherever processing takes place.	Met
Exposure: €20M. 4% of a turnover of €10M to €50M is about €1.2M; the fixed cap is €20M. The higher amount applies. Caveat: The data strand of the Digital Omnibus package, under negotiation since November 2025, could change the definition of personal data and the consent regime. No text has been adopted to date.		

NIS2 (ReCyF) Directive (EU) 2022/2555		Applicable · Important entity
LEGAL BASIS	CONDITION EXAMINED	STATUS
Annexes I and II	Sector covered by the directive The "Digital infrastructure" sector falls under Annex I (sectors of high criticality).	Met
Article 2(1)	Medium-sized enterprise threshold The entity reaches the medium-sized threshold: 50 staff, or turnover and balance sheet above €10M.	Met
Exposure: €7M. 1.4% of a turnover of €10M to €50M is about €420k; the fixed cap is €7M. The higher amount applies. Caveat: The directive has not been transposed in France as of 24 September 2026. Obligations will only be enforceable once the resilience act and its decrees are published, but the ReCyF published by ANSSI already sets out what is expected. Caveat: As a financial entity subject to DORA, Article 4 of NIS2 sets aside the directive's risk-management and incident-notification provisions, DORA being <i>lex specialis</i> . The entity remains part of the NIS2 ecosystem.		

DORA Regulation (EU) 2022/2554		Applicable · Financial entity
LEGAL BASIS	CONDITION EXAMINED	STATUS
Article 2(1)	Listed type of financial entity The entity is of type "paiement", listed in Article 2. The regulation applies directly and in full.	Met
Exposure: national regime. DORA sets no harmonised EU cap for financial entities: each Member State lays down effective, proportionate and dissuasive penalties. In France, the caps are those of the Monetary and Financial Code for the relevant category of entity. Authorities may also publish penalties and hold management personally liable. Caveat: DORA is <i>lex specialis</i> in relation to NIS2 (recital 16). The NIS2 risk-management and incident-notification provisions therefore do not apply in parallel.		

CRA Regulation (EU) 2024/2847		Applicable · Manufacturer, default product
LEGAL BASIS	CONDITION EXAMINED	STATUS
Article 2(1)	Placing products with digital elements on the market The entity acts as manufacturer. The regulation applies to the products it makes available on the Union market.	Met
Article 2(2) to (7)	No excluding sectoral legislation No sectoral exclusion reported.	Met
Articles 7, 8 and 32, Annexes III and IV	Category of the most exposed product The highest reported category is default product. Conformity assessment can be carried out internally (module A).	Met
Exposure: €15M. 2.5% of a turnover of €10M to €50M is about €750k; the fixed cap is €15M. The higher amount applies. Caveat: Phased application: reporting of exploited vulnerabilities and severe incidents has applied since 11 September 2026, including for products already on the market; essential requirements, CE marking and technical documentation apply from 11 December 2027. Caveat: In France, ANSSI is the notifying authority and market surveillance is expected to go to ANFR; formal designation is still pending.		

AI Act Regulation (EU) 2024/1689		Applicable · Deployer, limited risk
LEGAL BASIS	CONDITION EXAMINED	STATUS
Article 2(1)	Providing or using AI systems The entity acts as deployer. The AI literacy obligation (Art. 4) applies as soon as an AI system is used professionally.	Met
Article 5	No prohibited practice No prohibited practice reported.	Met
Article 6 and Annexes I and III	High-risk AI system No high-risk system reported.	Not met
Article 50	Transparency obligations The declared uses (interaction, generated content, deep fakes or emotion recognition) require informing people, applicable since 2 August 2026.	Met

Exposure: €900k. 3% of a turnover of €10M to €50M is about €900k; the fixed cap is €15M. The lower amount applies.

Caveat: A deployer that puts its name on a high-risk system, substantially modifies it or changes its intended purpose becomes a provider under Article 25.

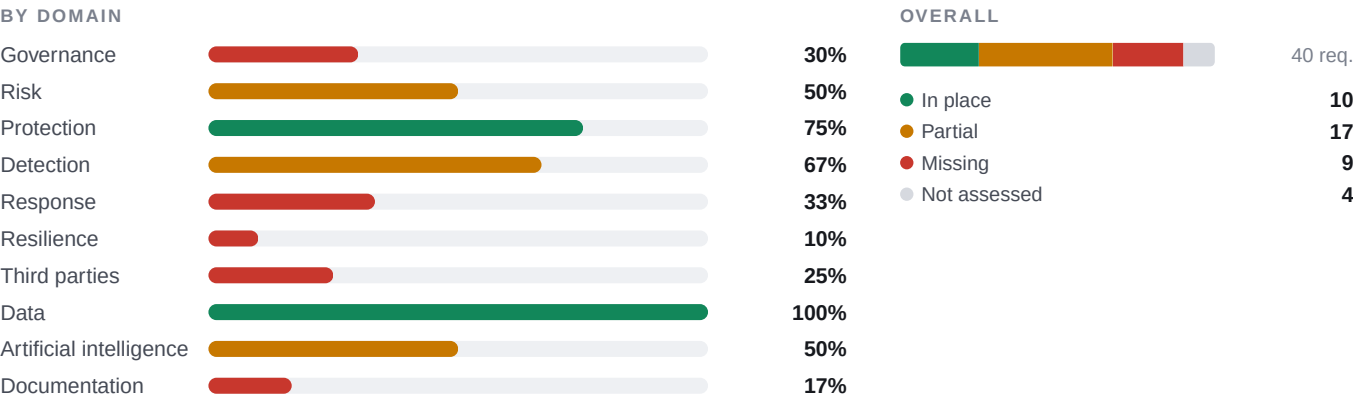
Caveat: In France, competent authorities have not yet been formally designated: the government plan gives coordination to the DGCCRF, alongside the CNIL and sectoral authorities.

02 Obligations in scope

TEXT	OBLIGATIONS KEPT	ELEMENTARY REQUIREMENTS	EXCLUDED
GDPR	18	65	3
NIS2 (ReCyF)	7	20	15
DORA	20	89	2
CRA	11	42	1
AI Act	5	16	13
Total	61	232	34

Financial entity: DORA replaces NIS2's risk-management and notification obligations (Article 4 of NIS2). The corresponding NIS2 obligations are counted as excluded.

03 Reported coverage



Declared ISO/IEC 27001 status: partial. 93 Annex A controls filled in; 10 unified requirements pre-filled from implemented controls; 1 mandatory requirement whose matching control was excluded from the initiative.

GAPS OBSERVED

26 requirements

RANK	UNIFIED REQUIREMENT	TEXTS	LEVEL	OWNER
1	Accountability of the management body	GDPR · NIS2 (ReCyF) · DORA · AI Act	● Missing	Executive management
2	Documentation and policies	GDPR · NIS2 (ReCyF) · DORA · CRA · AI Act	● Missing	Compliance
3	Notifying incidents to the authority	GDPR · NIS2 (ReCyF) · DORA · CRA · AI Act	● Missing	CISO
4	Backup and restoration	GDPR · NIS2 (ReCyF) · DORA	● Missing	IT department
5	Third-party register and mapping	GDPR · NIS2 (ReCyF) · DORA	● Missing	Procurement
6	Testing, exercises and audits	GDPR · NIS2 (ReCyF) · DORA · CRA · AI Act	● Missing	IT department
7	Lex specialis: DORA prevails over NIS2	DORA · NIS2 (ReCyF)	● Missing	Executive management
9	Inventory and classification of AI systems	AI Act · GDPR	● Missing	DPO
10	Transparency towards individuals	AI Act · GDPR	● Missing	DPO
12	Dedicated function and point of contact	GDPR · NIS2 (ReCyF) · DORA · CRA	● Partial	Executive management
13	Training and awareness	GDPR · NIS2 (ReCyF) · DORA · AI Act	● Partial	Executive management
14	Communicating with individuals and recipients	GDPR · NIS2 (ReCyF) · DORA · CRA	● Partial	CISO
15	Physical and environmental security	GDPR · NIS2 (ReCyF) · DORA	● Partial	to assign
16	Vulnerability management	NIS2 (ReCyF) · DORA · GDPR · CRA	● Partial	to assign
17	Prior impact assessment	GDPR · DORA · AI Act	● Partial	CISO
18	Risk analysis and risk-based approach	GDPR · NIS2 (ReCyF) · DORA · CRA · AI Act	● Partial	CISO
19	Identity and access management	GDPR · NIS2 (ReCyF) · DORA · CRA	● Partial	to assign
20	Security by design, development and change	GDPR · NIS2 (ReCyF) · DORA · CRA · AI Act	● Partial	to assign
21	Security detection and monitoring	NIS2 (ReCyF) · DORA · GDPR · AI Act	● Partial	to assign
22	Incident management process	GDPR · NIS2 (ReCyF) · DORA · CRA · AI Act	● Partial	CISO
23	Supply chain security	NIS2 (ReCyF) · DORA · GDPR · CRA · AI Act	● Partial	Procurement
24	System mapping and asset inventory	NIS2 (ReCyF) · DORA · GDPR · AI Act	● Partial	to assign
25	Business continuity and recovery	GDPR · NIS2 (ReCyF) · DORA	● Partial	IT department
26	Contractual framework with third parties	GDPR · NIS2 (ReCyF) · DORA · AI Act	● Partial	Procurement
28	Registration and identity declaration	NIS2 (ReCyF) · DORA	● Partial	Executive management
30	Prohibited AI practices	AI Act · GDPR	● Partial	DPO

04 Friction points between texts

On these subjects, the applicable texts do not overlap: they diverge, or one prevails over the other. Reading them text by text leads to mis-sizing.

Accountability of the management body GOV-01 · Divergence

The three main texts raise compliance to management-body level, but with very uneven legal consequences. The GDPR requires compliance to be demonstrated without targeting managers personally; NIS2 makes managers accountable for breaches of Article 21 and allows them to be banned from office; DORA gives them ultimate responsibility for the ICT risk management framework.

Rule applied: NIS2 (ReCyF) prevails: Mandatory training of management body members and personal liability that may go as far as a ban from office.

Dedicated function and point of contact GOV-02 · Divergence

Each text requires a reference person, but their statuses are incompatible: the data protection officer must be independent and free of conflicts of interest, while the NIS2 point of contact and the DORA officer are operational functions. Merging these roles in one person creates an enforceable conflict of interest.

Rule applied: GDPR prevails: Functional independence of the DPO, no conflict of interest, reporting to the highest level, protection from penalties for performing their tasks.

Logging and traceability DET-01 · Divergence

Logging illustrates a recurring tension: the cyber texts push for broad collection and retention, while the GDPR requires minimisation and limited retention. Logs containing identifiers and IP addresses are personal data.

Rule applied: DORA prevails: Retention sufficient for root-cause analysis and prudential reconstruction of incidents, which exceeds the default retention period for technical logs.

Notifying incidents to the authority REP-02 · Divergence

This is the most operational divergence of the whole set-up: several notification regimes, several authorities, several clocks. An incident affecting a bank and personal data can require a report to the ACPR, a warning to ANSSI and a notification to the CNIL, with different deadlines and contents.

Rule applied: DORA prevails: The DORA initial notification is the earliest of the whole set-up, and it uses a mandatory harmonised template that the entity cannot choose to skip.

Testing, exercises and audits RES-04 · Divergence

All the texts ask for the effectiveness of measures to be verified, but intensity varies widely: simple regular evaluation for the GDPR, audits reserved for essential entities in the ReCyF, a full programme and threat-led penetration tests every three years for DORA.

Rule applied: DORA prevails: Threat-led penetration test at least every three years, in live production, on a scope validated and attested by the authority.

Contractual framework with third parties TIE-01 · Divergence

The GDPR and DORA both impose mandatory contract terms, but they barely overlap: GDPR Article 28 covers data processing, DORA Article 30 covers service resilience. A contract compliant with one is not compliant with the other.

Rule applied: DORA prevails: Unrestricted rights of access, inspection and audit, quantitative performance targets, and an exit strategy with a sufficient transition period.

Prohibited AI practices IA-02 · Divergence

Article 5 prohibits uses, not technologies. Several of these bans overlap with processing the GDPR already strictly governed, such as biometric categorisation based on sensitive data. The AI Act turns them into outright bans, with the highest penalty cap in EU digital law.

Rule applied: AI Act prevails: Absolute ban on the Article 5 practices, punishable by up to €35M or 7% of worldwide turnover.

Lex specialis: DORA prevails over NIS2 HIE-01 · Precedence

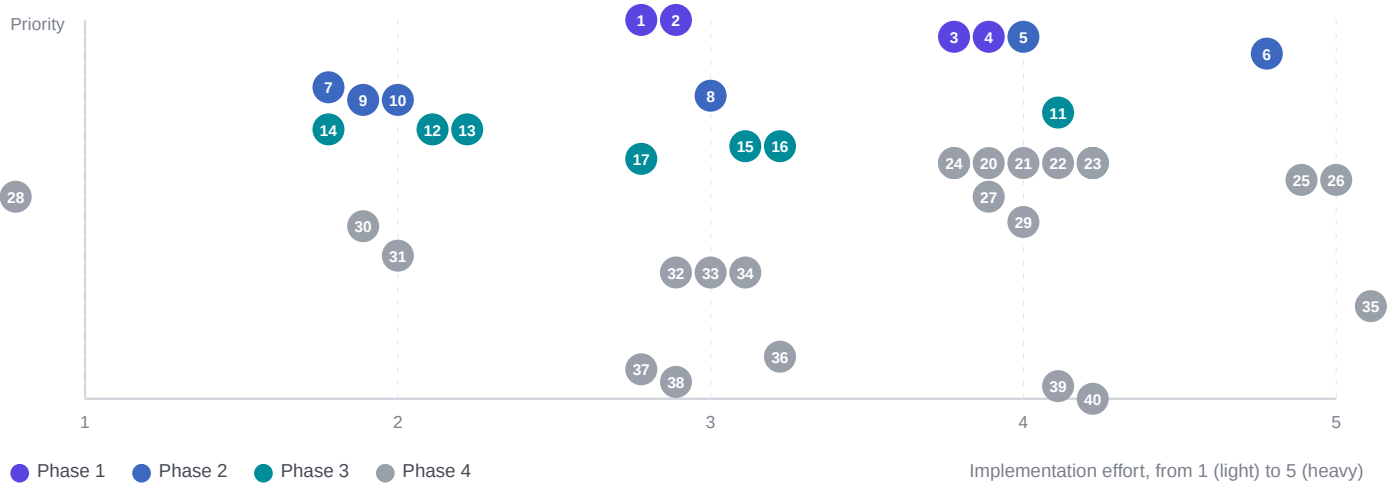
DORA expressly declares itself *lex specialis* in relation to NIS2. NIS2 Article 4 draws the consequence: where a sectoral act imposes requirements of at least equivalent effect, the corresponding NIS2 provisions no longer apply. A financial entity subject to DORA therefore does not apply NIS2's risk-management and notification regime in parallel.

Rule applied: DORA recital 16: "this Regulation constitutes *lex specialis* with regard to Directive (EU) 2022/2555". NIS2 Article 4: the provisions of the directive do not apply where sectoral acts impose requirements of at least equivalent effect.

05 Treatment plan

The order results from an explicit weighting (legal exposure 30, observed gap 30, leverage 20, time pressure 10, low effort 10), adjusted for technical prerequisites. Horizons are indicative; the sequence is what commits.

PRIORITY AND EFFORT OF EACH REQUIREMENT



PHASE 1

0 to 3 months · 4 requirements

Remove the most serious exposure and lay the groundwork everything else depends on.

RANK	REQUIREMENT AND EXPECTED ACTION	TEXTS	TODAY	EFFORT
1	Accountability of the management body Set up a single governance body (a security and compliance committee) that formally approves policies, monitors indicators and records its decisions. A single, properly drafted resolution counts as approval under each of these texts.	GDPR · NIS2 (ReCyF) · ● Missing DORA · AI Act		3/5
2	Documentation and policies Build a single documentation set, with a framework policy and topic policies, each carrying a mapping table to the articles it satisfies. This table is what turns an internal document into evidence of compliance.	GDPR · NIS2 (ReCyF) · ● Missing DORA · CRA · AI Act		3/5
3	Notifying incidents to the authority Build a single notification matrix (event, qualification, authority, deadline, template, owner) and rehearse it. The shortest clock drives the mobilisation of the crisis unit, even if the other deadlines are longer.	GDPR · NIS2 (ReCyF) · ● Missing DORA · CRA · AI Act		4/5
4	Backup and restoration Define a single backup policy aligned on the DORA level: scope and frequency by criticality, physical and logical isolation, periodic restoration tests in a separate environment.	GDPR · NIS2 (ReCyF) · ● Missing DORA		4/5

PHASE 2

3 to 6 months · 6 requirements

Tackle high-leverage requirements once the foundations are in place.

RANK	REQUIREMENT AND EXPECTED ACTION	TEXTS	TODAY	EFFORT
5	Third-party register and mapping Keep a single supplier repository whose attributes are the superset of the three requirements, and generate by extraction the DORA register of information, the recipients section of the GDPR record and the NIS2 map.	GDPR · NIS2 (ReCyF) · ● Missing DORA		4/5
6	Testing, exercises and audits Build a single multi-year control plan combining internal controls, audits, technical tests and exercises, whose depth is calibrated on the most demanding regime applicable to the entity.	GDPR · NIS2 (ReCyF) · ● Missing DORA · CRA · AI Act		5/5
7	Lex specialis: DORA prevails over NIS2 For a financial entity, apply DORA as the reference regime for ICT risk management and incident notification. NIS2 still has effects on points not covered by DORA, and the entity remains part of the NIS2 ecosystem (cooperation group, CSIRT).	DORA · NIS2 (ReCyF) · ● Missing		2/5

8	Security maintenance and end of life Keep a single register of products and components with their end-of-support date (those the entity guarantees as manufacturer, and those it depends on as a user) and plan each migration before the deadline.	CRA · NIS2 (ReCyF) · DORA	● Not assessed	3/5
9	Inventory and classification of AI systems Keep a single inventory of AI systems, linked to the record of processing: for each system, purpose, provider, the entity's role, data processed, reasoned risk level and owner. Review the classification for each new use case.	AI Act · GDPR	● Missing	2/5
10	Transparency towards individuals Write single notices at the relevant touchpoints (chatbot, generated content, emotion recognition) that cover both the GDPR information and AI Act transparency, and technically mark generated content.	AI Act · GDPR	● Missing	2/5

PHASE 3

6 to 12 months · 8 requirements

Consolidate and formalise, ready for an inspection.

RANK	REQUIREMENT AND EXPECTED ACTION	TEXTS	TODAY	EFFORT
11	Regulatory registers Feed the registers from a common base (asset inventory, supplier repository, incident register) rather than keeping them separately. The output format differs; the input data is largely the same.	GDPR · DORA · NIS2 (ReCyF) · AI Act	● Not assessed	4/5
12	Dedicated function and point of contact Map the roles required by each applicable text and assign them separately, documenting the absence of conflict of interest for the DPO role. One department can coordinate them, but the DPO cannot be the person deciding on the means of processing.	GDPR · NIS2 (ReCyF) · DORA · CRA	● Partial	2/5
13	Training and awareness Build an annual three-tier programme (management body, staff, sensitive profiles) covering data protection, cybersecurity and resilience, with attendance tracking and assessment. One programme, three tracks.	GDPR · NIS2 (ReCyF) · DORA · AI Act	● Partial	2/5
14	Communicating with individuals and recipients Prepare a set of communication templates per audience and per trigger, validated in advance by legal and communications, so that drafting is not done under the pressure of the crisis.	GDPR · NIS2 (ReCyF) · DORA · CRA	● Partial	2/5
15	Physical and environmental security Treat physical security as a full part of the security policy: access control to premises, intrusion detection, monitoring, protection of areas hosting critical systems.	GDPR · NIS2 (ReCyF) · DORA	● Partial	3/5
16	Vulnerability management Run a single vulnerability management cycle with monitoring, fix deadlines differentiated by criticality, and a coordinated disclosure channel reachable from outside.	NIS2 (ReCyF) · DORA · GDPR · CRA	● Partial	3/5
17	Prior impact assessment Build the trigger for an impact assessment into the project design milestone, reusing the outputs of the general risk analysis for threats and measures. Only the part on harm to rights and freedoms is GDPR-specific.	GDPR · DORA · AI Act	● Partial	3/5
18	Risk analysis and risk-based approach Run a single risk analysis, structured by asset and function, whose outputs feed every reading: impact on individuals, on services, on critical functions, on physical continuity. One method (EBIOS Risk Manager works well) and several outputs.	GDPR · NIS2 (ReCyF) · DORA · CRA · AI Act	● Partial	4/5

PHASE 4

Beyond 12 months · 22 requirements

Go further, and prepare for regimes not yet in force.

RANK	REQUIREMENT AND EXPECTED ACTION	TEXTS	TODAY	EFFORT
19	Identity and access management Deploy a single identity management set-up: least privilege, periodic access reviews, multi-factor authentication on remote access and privileged accounts, and strict separation of administration accounts.	GDPR · NIS2 (ReCyF) · DORA · CRA	● Partial	4/5

20	Security by design, development and change Insert a single security and data protection milestone into the project life cycle, covering security requirements, minimisation, default settings, code review and a change procedure with rollback.	GDPR · NIS2 (ReCyF) ·  Partial DORA · CRA · AI Act	4/5
21	Security detection and monitoring Set up a detection capability sized on the category: detection and alert handling for all entities, continuous monitoring with event analysis for essential entities and financial entities.	NIS2 (ReCyF) · DORA ·  Partial GDPR · AI Act	4/5
22	Incident management process Build a single incident management procedure whose qualification step applies all the grids in parallel and automatically triggers the corresponding notifications. The process is shared; only the qualification is multiple.	GDPR · NIS2 (ReCyF) ·  Partial DORA · CRA · AI Act	4/5
23	Supply chain security Set up a supplier assessment proportionate to criticality, requiring visibility of downstream subcontractors, and review it periodically rather than only at contract signature.	NIS2 (ReCyF) · DORA ·  Partial GDPR · CRA · AI Act	4/5
24	System mapping and asset inventory Build and maintain a single map (activities and services, systems supporting them, hardware and software assets, internal and external dependencies, an owner per entry) and review it annually.	NIS2 (ReCyF) · DORA ·  Partial GDPR · AI Act	4/5
25	Business continuity and recovery Build a single business continuity plan, based on the critical functions identified, with recovery time and recovery point objectives per function, tested at least annually.	GDPR · NIS2 (ReCyF) ·  Partial DORA	5/5
26	Contractual framework with third parties Build a single body of clauses organised in three blocks (data protection under GDPR Article 28, resilience and service under DORA Article 30, supply chain security under NIS2 Article 21(2)(d)) and tailor it to the type of provider.	GDPR · NIS2 (ReCyF) ·  Partial DORA · AI Act	5/5
27	Crisis management Formalise a single crisis set-up (membership, trigger criteria, log, backup communication outside the main information system) and exercise it at a defined frequency.	NIS2 (ReCyF) · DORA  Not assessed	4/5
28	Registration and identity declaration Build a single regulatory identity sheet (legal name, establishments, IP ranges, sectors, Member States served, contacts) and keep it as the single source for all declarations. Set a two-week alert on any change.	NIS2 (ReCyF) · DORA  Partial	1/5
29	Concentration and exit strategy Document, for each provider supporting a critical function, a substitutability analysis and an operational exit strategy, not just a reversibility clause.	DORA · GDPR  Not assessed	4/5
30	Prohibited AI practices Submit every AI project to a prior review against Article 5 and the Commission guidelines, recorded in the inventory. Treat any doubt as a blocker until a reasoned decision is made.	AI Act · GDPR  Partial	2/5
31	Location and sovereignty Document location choices and their justification, and anticipate the Union-presence requirements on critical providers, without confusing a legal obligation with a sovereignty recommendation.	DORA · GDPR · NIS2 (ReCyF)  In place	2/5
32	Encryption and cryptography Write a single cryptography policy defining algorithms, key lengths, use cases and life-cycle management, then apply it at rest and in transit. This policy serves both as an Article 32 measure and as a potential Article 34 exemption.	GDPR · NIS2 (ReCyF) ·  In place DORA · CRA	3/5
33	Logging and traceability Define a single logging policy setting, per log category, what is collected, why, for how long and who has access, then enter this policy in the record of processing. Detection needs set the floor, minimisation sets the ceiling.	GDPR · NIS2 (ReCyF) ·  In place DORA · AI Act	3/5
34	Lawfulness, purpose and minimisation Treat security and resilience set-ups as processing in their own right: enter them in the record, give them a legal basis and limit their retention. This is where a poorly run cyber initiative creates GDPR risk.	GDPR · NIS2 (ReCyF) ·  In place CRA · AI Act	3/5

35	Technical and organisational security measures Establish a single information security policy whose structure follows the ten measures of NIS2 Article 21(2) and the chapters of Delegated Regulation 2024/1774. This structure covers GDPR Article 32, which is less demanding, by design.	GDPR · NIS2 (ReCyF) · DORA · CRA · AI Act	● In place	5/5
36	Human resources security Formalise joiner, mover and leaver procedures with systematic removal of access, identify sensitive functions, and frame any background check with a GDPR-compliant legal basis and information to individuals.	GDPR · NIS2 (ReCyF)	● In place	3/5
37	Human oversight of AI-assisted decisions Designate, train and empower people in charge of human oversight of high-risk systems, able to disregard or stop the system, and document the human intervention procedure open to the people concerned.	AI Act · GDPR	● In place	3/5
38	Data subject rights Check, for each technical security and resilience set-up, that it does not prevent rights from being exercised, especially erasure in backups and rectification in logs.	GDPR · DORA	● In place	3/5
39	Quality and governance of training data Document each training data set (origin, legal basis, preparation, bias analysis) and check that reuse is compatible with the original purpose. Publish the training data summary for general-purpose models.	AI Act · GDPR	● In place	4/5
40	International transfers Keep a single map of data and processing locations, including remote access from third countries, and derive from it the GDPR transfer basis and the DORA contract term.	GDPR · DORA	● In place	4/5

06 Reporting readiness

TEXT	AUTHORITY	STEPS AND DEADLINES
GDPR	CNIL	Notification 72 h
NIS2 (ReCyF)	Reported under DORA	Article 4 of NIS2: DORA prevails for a financial entity.
DORA	ACPR	Initial notification 4 h* · Intermediate report 72 h · Final report 1 month
CRA	ENISA, single reporting platform	Early warning 24 h · Notification 72 h · Final report 14 d / 1 month
AI Act	Market surveillance authority (AI)	Critical infrastructure, widespread 2 d · Death 10 d · Other serious incident 15 d

* DORA: 4 h after classification as a major incident, and no later than 24 h after detection (Delegated Regulation 2025/301).

READINESS

- Competent authorities identified
- Security lead designated
- Technical response support identified
- Data protection officer reachable
- Executive decision-maker designated
- DORA classification criteria known

ESCALATION CHAIN

- CISO** : Karim Benali, Chief information security officer
- Response** : Astreinte 24/7, PRIS-qualified incident response provider, call-out contract
- DPO** : Claire Morel, Data protection officer
- Management** : Thomas Lefèvre, Deputy chief executive
- Legal** : Inès Garnier, Head of compliance

07 Timeline

DATE	TEXT	MILESTONE
7 October 2026	NIS2 (ReCyF)	Resilience bill debated in the National Assembly The conference of presidents of 22 September 2026 put the bill transposing NIS2 on the public session agenda from 7 October. It is the first concrete signal of an enforceable compliance timetable in France.
2 December 2026	AI Act	New prohibition and end of the marking grace period Ban on systems generating child sexual abuse material or non-consensual intimate content, and end of the grace period granted to systems already on the market to mark the content they generate.

31 December 2026	Cross-cutting	Expected enactment of the resilience act The bill on the resilience of critical infrastructure and strengthening cybersecurity transposes NIS2 and DORA's accompanying directive. After the public session debate opening on 7 October, the shuttle between chambers, implementing decrees and the final ReCyF will follow. Indicative date.
17 April 2027	NIS2 (ReCyF)	First biennial review of national lists Member States review and update the list of essential and important entities at least every two years.
11 December 2027	CRA	CRA fully applies Essential requirements, conformity assessment, CE marking and the obligations of importers and distributors become enforceable. A non-compliant product can no longer be placed on the Union market.

RECURRING DUTIES

TEXT	OBLIGATION	FREQUENCY
DORA	Submission of the register of information	Annual
DORA	Testing of systems supporting critical functions	Annual
DORA	Threat-led penetration test	Every three years
DORA	Review of the ICT risk management framework	Annual, and after each major incident
NIS2 (ReCyF)	Review of the security policy and the list of systems	Annual
NIS2 (ReCyF)	Review of accounts, access rights and filtering rules	Annual
NIS2 (ReCyF)	Backup and restoration testing	Annual
NIS2 (ReCyF)	Review of the risk analysis	Every three years, and after an incident
NIS2 (ReCyF)	Training and exercise programme	Three-year programme
GDPR	Update of the record of processing	Ongoing
CRA	Monitoring of support periods	Ongoing
AI Act	Review of the inventory and classification of AI systems	With each new use case
AI Act	Retention of high-risk system logs	Ongoing

08 Interview log

Points raised during scoping. The checks and evidence listed remain open as of the report date.	
POINTS TO CHECK	1
SUBJECT	NOTE
Type of financial entity	Confirm that the ACPR authorisation does not also cover issuing electronic money: that would change the type of financial entity.
EVIDENCE REQUESTED	1
SUBJECT	NOTE
Third-party register and mapping	Obtain the register of ICT providers kept by Procurement (format and date of last update).
ASSUMPTIONS MADE	1
SUBJECT	NOTE
Products with digital elements	The payment SDK is distributed free of charge but bundled into a paid offer: treated as placed on the market under the CRA.

DECISIONS TAKEN		1
SUBJECT	NOTE	
Dedicated function and point of contact	The DPO and the CISO remain two separate functions; the CISO becomes the DORA point of contact.	

09 Method, caveats and sources

Nature of the document: a scoping deliverable. It establishes a likely scope and a treatment order; it is neither a compliance audit nor legal advice. Conclusions rely on the information provided, whose accuracy is not verified.

Qualifications for a third party to decide: designation as a critical entity (Article 3(1)(f) NIS2), identification for threat-led penetration testing (DORA) and listing as an essential or important entity are for the competent authorities.

Law as of 24 September 2026: NIS2 has not been transposed in France; its requirements are detailed by the ReCyF, an ANSSI working document. The CRA has required reporting of actively exploited vulnerabilities since 11 September 2026 and fully applies on 11 December 2027. The AI Act applies in stages; the AI Omnibus postponed high-risk systems to 2 December 2027 (Annex III) and 2 August 2028 (Annex I).

- SOURCES
- Regulation (EU) 2016/679: GDPR
 - Directive (EU) 2022/2555: NIS2 (ReCyF)
 - Regulation (EU) 2022/2554: DORA
 - Regulation (EU) 2024/2847: CRA
 - Regulation (EU) 2024/1689: AI Act
 - Delegated Regulation (EU) 2025/301: reporting of major ICT-related incidents
 - Regulation (EU) 2026/1744: Digital Omnibus on AI
 - French cyber framework (ReCyF) v2.5: ANSSI, 17 March 2026